

CVEs más relevantes de la semana

Del 28/03/2026 al 04/04/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2025-15604

Descripción: Amon2 versions before 6.17 for Perl use an insecure random_string implementation for security functions.

In versions 6.06 through 6.16, the random_string function will attempt to read bytes from the /dev/urandom device, but if that is unavailable then it generates bytes by concatenating a SHA-1 hash seeded with the built-in rand() function, the PID, and the high resolution epoch time. The PID...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-338

Tecnología: No especificado

Publicado el: 2026-03-28



CVE-2026-3256

Descripción: HTTP::Session versions through 0.53 for Perl defaults to using insecurely generated session ids.

HTTP::Session defaults to using HTTP::Session::ID::SHA1 to generate session ids using a SHA-1 hash seeded with the built-in rand function, the high resolution epoch time, and the PID. The PID will come from a small set of numbers, and the epoch time may be guessed, if it is not leaked from the HTTP...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-338

Tecnología: No especificado

Publicado el: 2026-03-28



CVE-2026-5017

Descripción: A security flaw has been discovered in code-projects Simple Food Order System 1.0. This impacts an unknown function of the file /all-tickets.php of the component Parameter Handler. Performing a manipulation of the argument Status results in sql injection. The attack can be initiated remotely. The exploit has been released to the public and may be used for attacks.

CVSS: 7.3 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-03-28



CVE-2026-5018

Descripción: A weakness has been identified in code-projects Simple Food Order System 1.0. Affected is an unknown function of the file register-router.php of the component Parameter Handler. Executing a manipulation of the argument Name can lead to sql injection. The attack can be launched remotely. The exploit has been made available to the public and could be used for attacks.

CVSS: 7.3 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-03-28



CVE-2026-5019

Descripción: A security vulnerability has been detected in code-projects Simple Food Order System 1.0. Affected by this vulnerability is an unknown functionality of the file all-orders.php of the component Parameter Handler. The manipulation of the argument Status leads to sql injection. The attack may be initiated remotely. The exploit has been disclosed publicly and may be used.

CVSS: 7.3 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-03-29



CVE-2026-4851

Descripción: GRID::Machine versions through 0.127 for Perl allows arbitrary code execution via unsafe deserialization.

GRID::Machine provides Remote Procedure Calls (RPC) over SSH for Perl. The client connects to remote hosts to execute code on them. A compromised or malicious remote host can execute arbitrary code back on the client through unsafe deserialization in the RPC protocol.

read_operation() in ...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-95

Tecnología: No especificado

Publicado el: 2026-03-29



CVE-2026-5020

Descripción: A vulnerability was detected in Totolink A3600R 4.1.2cu.5182_B20201102. Affected by this issue is the function setNoticeCfg of the file /cgi-bin/cstecgi.cgi of the component Parameter Handler. The manipulation of the argument NoticeUrl results in command injection. The attack may be launched remotely. The exploit is now public and may be used.

CVSS: 6.3 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:L

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-03-29



CVE-2026-5030

Descripción: A vulnerability has been found in Totolink NR1800X 9.1.0u.6279_B20210910. This issue affects the function NTPSyncWithHost of the file /cgi-bin/cstecgi.cgi of the component Telnet Service. The manipulation of the argument host_time leads to command injection. The attack can be initiated remotely. The exploit has been disclosed to the public and may be used.

CVSS: 6.3 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:L

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-03-29



CVE-2026-5033

Descripción: A vulnerability was detected in code-projects Accounting System 1.0. Affected by this vulnerability is an unknown functionality of the file /view_costumer.php of the component Parameter Handler. The manipulation of the argument cos_id results in sql injection. The attack may be performed from remote. The exploit is now public and may be used.

CVSS: 7.3 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-03-29



CVE-2026-5034

Descripción: A flaw has been found in code-projects Accounting System 1.0. Affected by this issue is some unknown functionality of the file /edit_costumer.php of the component Parameter Handler. This manipulation of the argument cos_id causes sql injection. It is possible to initiate the attack remotely. The exploit has been published and may be used.

CVSS: 7.3 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-03-29



CVE-2026-5035

Descripción: A vulnerability has been found in code-projects Accounting System 1.0. This affects an unknown part of the file /view_work.php of the component Parameter Handler. Such manipulation of the argument en_id leads to sql injection. It is possible to launch the attack remotely. The exploit has been disclosed to the public and may be used.

CVSS: 7.3 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-03-29



CVE-2026-32922

Descripción: OpenClaw before 2026.3.11 contains a privilege escalation vulnerability in device.token.rotate that allows callers with operator.pairing scope to mint tokens with broader scopes by failing to constrain newly minted scopes to the caller's current scope set. Attackers can obtain operator.admin tokens for paired devices and achieve remote code execution on connected nodes via system.run or gain un...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-266

Tecnología: No especificado

Publicado el: 2026-03-29



CVE-2026-32924

Descripción: OpenClaw before 2026.3.12 contains an authorization bypass vulnerability where Feishu reaction events with omitted chat_type are misclassified as p2p conversations instead of group chats. Attackers can exploit this misclassification to bypass groupAllowFrom and requireMention protections in group chat reaction-derived events.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-863

Tecnología: No especificado

Publicado el: 2026-03-29



CVE-2026-32973

Descripción: OpenClaw before 2026.3.11 contains an exec allowlist bypass vulnerability where matchesExecAllowlistPattern improperly normalizes patterns with lowercasing and glob matching that overmatches on POSIX paths. Attackers can exploit the ? wildcard matching across path segments to execute commands or paths not intended by operators.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-625

Tecnología: No especificado

Publicado el: 2026-03-29



CVE-2026-32974

Descripción: OpenClaw before 2026.3.12 contains an authentication bypass vulnerability in Feishu webhook mode when only verificationToken is configured without encryptKey, allowing acceptance of forged events. Unauthenticated network attackers can inject forged Feishu events and trigger downstream tool execution by reaching the webhook endpoint.

CVSS: 8.6 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L

Tipo: CWE-347

Tecnología: No especificado

Publicado el: 2026-03-29



CVE-2026-32975

Descripción: OpenClaw before 2026.3.12 contains a weak authorization vulnerability in Zalouser allowlist mode that matches mutable group display names instead of stable group identifiers. Attackers can create groups with identical names to allowlisted groups to bypass channel authorization and route messages from unintended groups to the agent.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-807

Tecnología: No especificado

Publicado el: 2026-03-29



CVE-2026-32987

Descripción: OpenClaw before 2026.3.13 allows bootstrap setup codes to be replayed during device pairing verification in `src/infra/device-bootstrap.ts`. Attackers can verify a valid bootstrap code multiple times before approval to escalate pending pairing scopes, including privilege escalation to `operator.admin`.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-294

Tecnología: No especificado

Publicado el: 2026-03-29



CVE-2026-0558

Descripción: A vulnerability in parisneo/lollms, up to and including version 2.2.0, allows unauthenticated users to upload and process files through the `/api/files/extract-text` endpoint. This endpoint does not enforce authentication, unlike other file-related endpoints, and lacks the `Depends(get_current_active_user)` dependency. This issue can lead to denial of service (DoS) through resource exhaustion, ...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-03-29



CVE-2026-33030

Descripción: Nginx UI is a web user interface for the Nginx web server. In versions 2.3.3 and prior, Nginx-UI contains an Insecure Direct Object Reference (IDOR) vulnerability that allows any authenticated user to access, modify, and delete resources belonging to other users. The application's base Model struct lacks a user_id field, and all resource endpoints perform queries by ID without verifying user ow...

CVSS: 8.8 (HIGH)

Vector: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-03-30



CVE-2026-28505

Descripción: Tautulli is a Python based monitoring and tracking tool for Plex Media Server. Prior to version 2.17.0, the `str_eval()` function in `notification_handler.py` implements a sandboxed `eval()` for notification text templates. The sandbox attempts to restrict callable names by inspecting `code.co_names` of the compiled code object. However, `co_names` only contains names from the outer code object. When a l...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-03-30



CVE-2026-33026

Descripción: Nginx UI is a web user interface for the Nginx web server. Prior to version 2.3.4, the nginx-ui backup restore mechanism allows attackers to tamper with encrypted backup archives and inject malicious configuration during restoration. This issue has been patched in version 2.3.4.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-312

Tecnología: No especificado

Publicado el: 2026-03-30



CVE-2026-4257

Descripción: The Contact Form by Supsystic plugin for WordPress is vulnerable to Server-Side Template Injection (SSTI) leading to Remote Code Execution (RCE) in all versions up to, and including, 1.7.36. This is due to the plugin using the Twig `Twig\_Loader\_String` template engine without sandboxing, combined with the `cfsPreFill` prefill functionality that allows unauthenticated users to inject arbitrary T...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-03-30



CVE-2026-27697

Descripción: baserCMS is a website development framework. Prior to version 5.2.3, baserCMS has a SQL injection vulnerability in blog posts. This issue has been patched in version 5.2.3.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-03-31



CVE-2026-30880

Descripción: baserCMS is a website development framework. Prior to version 5.2.3, baserCMS has an OS command injection vulnerability in the installer. This issue has been patched in version 5.2.3.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-03-31



CVE-2026-3300

Descripción: The Everest Forms Pro plugin for WordPress is vulnerable to Remote Code Execution via PHP Code Injection in all versions up to, and including, 1.9.12. This is due to the Calculation Addon's `process_filter()` function concatenating user-submitted form field values into a PHP code string without proper escaping before passing it to `eval()`. The `sanitize_text_field()` function applied to input does n...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-03-31



CVE-2026-32916

Descripción: OpenClaw versions 2026.3.7 before 2026.3.11 contain an authorization bypass vulnerability where plugin subagent routes execute gateway methods through a synthetic operator client with broad administrative scopes. Remote unauthenticated requests to plugin-owned routes can invoke runtime.subagent methods to perform privileged gateway actions including session deletion and agent execution.

CVSS: 9.4 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L

Tipo: CWE-266

Tecnología: No especificado

Publicado el: 2026-03-31



CVE-2026-32917

Descripción: OpenClaw before 2026.3.13 contains a remote command injection vulnerability in the iMessage attachment staging flow that allows attackers to execute arbitrary commands on configured remote hosts. The vulnerability exists because unsanitized remote attachment paths containing shell metacharacters are passed directly to the SCP remote operand without validation, enabling command execution when re...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-03-31



CVE-2026-34162

Descripción: FastGPT is an AI Agent building platform. Prior to version 4.14.9.5, the FastGPT HTTP tools testing endpoint (/api/core/app/httpTools/runTool) is exposed without any authentication. This endpoint acts as a full HTTP proxy — it accepts a user-supplied baseUrl, toolPath, HTTP method, custom headers, and body, then makes a server-side HTTP request and returns the complete response to the caller. T...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:L

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-03-31



CVE-2026-34532

Descripción: Parse Server is an open source backend that can be deployed to any infrastructure that can run Node.js. Prior to versions 8.6.67 and 9.7.0-alpha.11, an attacker can bypass Cloud Function validator access controls by appending "prototype.constructor" to the function name in the URL. When a Cloud Function handler is declared using the function keyword and its validator is a plain object or arrow ...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-863

Tecnología: No especificado

Publicado el: 2026-03-31



CVE-2026-34221

Descripción: MikroORM is a TypeScript ORM for Node.js based on Data Mapper, Unit of Work and Identity Map patterns. Prior to versions 6.6.10 and 7.0.6, a prototype pollution vulnerability exists in the Utils.merge helper used internally by MikroORM when merging object structures. The function did not prevent special keys such as `__proto__`, `constructor`, or `prototype`, allowing attacker-controlled input to mod...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-1321

Tecnología: No especificado

Publicado el: 2026-03-31



CVE-2026-34235

Descripción: PJSIP is a free and open source multimedia communication library written in C. Prior to version 2.17, a heap out-of-bounds read vulnerability exists in PJSIP's VP9 RTP unpacketizer that occurs when parsing crafted VP9 Scalability Structure (SS) data. Insufficient bounds checking on the payload descriptor length may cause reads beyond the allocated RTP payload buffer. This issue has been patched...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:H

Tipo: CWE-125

Tecnología: No especificado

Publicado el: 2026-03-31



CVE-2026-24148

Descripción: NVIDIA Jetson for JetPack contains a vulnerability in the system initialization logic, where an unprivileged attacker could cause the initialization of a resource with an insecure default. A successful exploit of this vulnerability might lead to information disclosure of encrypted data, data tampering, and partial denial of service across devices sharing the same machine ID.

CVSS: 8.3 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:L

Tipo: CWE-1188

Tecnología: No especificado

Publicado el: 2026-03-31



CVE-2026-24164

Descripción: NVIDIA BioNeMo contains a vulnerability where a user could cause a deserialization of untrusted data. A successful exploit of this vulnerability might lead to code execution, denial of service, information disclosure, and data tampering.

CVSS: 8.8 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-03-31



CVE-2026-34359

Descripción: HAPI FHIR is a complete implementation of the HL7 FHIR standard for healthcare interoperability in Java. Prior to version 6.9.4, ManagedWebAccessUtils.getServer() uses String.startsWith() to match request URLs against configured server URLs for authentication credential dispatch. Because configured server URLs (e.g., http://tx.fhir.org) lack a trailing slash or host boundary check, an attacker-...

CVSS: 7.4 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-346

Tecnología: No especificado

Publicado el: 2026-03-31



CVE-2026-34361

Descripción: HAPI FHIR is a complete implementation of the HL7 FHIR standard for healthcare interoperability in Java. Prior to version 6.9.4, the FHIR Validator HTTP service exposes an unauthenticated "/loadIG" endpoint that makes outbound HTTP requests to attacker-controlled URLs. Combined with a startsWith() URL prefix matching flaw in the credential provider (ManagedWebAccessUtils.getServer()), an attack...

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:L/A:N

Tipo: CWE-552

Tecnología: No especificado

Publicado el: 2026-03-31



CVE-2025-71279

Descripción: XenForo before 2.3.7 contains a security issue affecting Passkeys that have been added to user accounts. An attacker may be able to compromise the security of Passkey-based authentication.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-04-01



CVE-2025-71281

Descripción: XenForo before 2.3.7 does not properly restrict methods callable from within templates. A loose prefix match was used instead of a stricter first-word match for methods accessible through callbacks and variable method calls in templates, potentially allowing unauthorized method invocations.

CVSS: 8.8 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-04-01



CVE-2026-5256

Descripción: A flaw has been found in code-projects Simple Laundry System 1.0. This vulnerability affects unknown code of the file /modify.php of the component Parameter Handler. This manipulation of the argument firstName causes sql injection. Remote exploitation of the attack is possible. The exploit has been published and may be used.

CVSS: 7.3 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-04-01



CVE-2026-5257

Descripción: A vulnerability has been found in code-projects Simple Laundry System 1.0. This issue affects some unknown processing of the file /delstaffinfo.php of the component Parameter Handler. Such manipulation of the argument userid leads to sql injection. The attack can be executed remotely. The exploit has been disclosed to the public and may be used.

CVSS: 7.3 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-04-01



CVE-2026-34430

Descripción: ByteDance Deer-Flow versions prior to commit 92c7a20 contain a sandbox escape vulnerability in bash tool handling that allows attackers to execute arbitrary commands on the host system by bypassing regex-based validation using shell features such as directory changes and relative paths. Attackers can exploit the incomplete shell semantics modeling to read and modify files outside the sandbox bo...

CVSS: 8.8 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Tipo: CWE-184

Tecnología: No especificado

Publicado el: 2026-04-01



CVE-2026-20093

Descripción: A vulnerability in the change password functionality of Cisco Integrated Management Controller (IMC) could allow an unauthenticated, remote attacker to bypass authentication and gain access to the system as Admin. This vulnerability is due to incorrect handling of password change requests. An attacker could exploit this vulnerability by sending a crafted HTTP request to an affected devi...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-04-01



CVE-2026-20160

Descripción: A vulnerability in Cisco Smart Software Manager On-Prem (SSM On-Prem) could allow an unauthenticated, remote attacker to execute arbitrary commands on the underlying operating system of an affected SSM On-Prem host. This vulnerability is due to the unintentional exposure of an internal service. An attacker could exploit this vulnerability by sending a crafted request to the API of the e...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-668

Tecnología: No especificado

Publicado el: 2026-04-01



CVE-2026-33615

Descripción: An unauthenticated remote attacker can exploit an unauthenticated SQL Injection vulnerability in the setinfo endpoint due to improper neutralization of special elements in a SQL UPDATE command. This can result in a total loss of integrity and availability.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-04-02



CVE-2026-26135

Descripción: Server-side request forgery (ssrf) in Azure Custom Locations Resource Provider (RP) allows an authorized attacker to elevate privileges over a network.

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-918

Tecnología: No especificado

Publicado el: 2026-04-03



CVE-2026-32211

Descripción: Missing authentication for critical function in Azure MCP Server allows an unauthorized attacker to disclose information over a network.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-04-03



CVE-2026-32213

Descripción: Improper authorization in Azure AI Foundry allows an unauthorized attacker to elevate privileges over a network.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-285

Tecnología: No especificado

Publicado el: 2026-04-03



CVE-2026-33105

Descripción: Improper authorization in Microsoft Azure Kubernetes Service allows an unauthorized attacker to elevate privileges over a network.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-285

Tecnología: No especificado

Publicado el: 2026-04-03



CVE-2026-33107

Descripción: Server-side request forgery (ssrf) in Azure Databricks allows an unauthorized attacker to elevate privileges over a network.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-918

Tecnología: No especificado

Publicado el: 2026-04-03



CVE-2017-20237

Descripción: Hirschmann Industrial HiVision versions prior to 06.0.07 and 07.0.03 contains an authentication bypass vulnerability in the master service that allows unauthenticated remote attackers to execute arbitrary commands with administrative privileges. Attackers can invoke exposed interface methods over the remote service to bypass authentication and achieve remote code execution on the underlying ope...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-04-03



CVE-2018-25237

Descripción: Hirschmann HiSecOS devices versions prior to 05.3.03 contain a buffer overflow vulnerability in the HTTPS login interface when RADIUS authentication is enabled that allows remote attackers to crash the device or execute arbitrary code by submitting a password longer than 128 characters. Attackers can exploit improper bounds checking in password handling to overflow a fixed-size buffer and achie...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-120

Tecnología: No especificado

Publicado el: 2026-04-03



CVE-2017-20234

Descripción: GarrettCom Magnum 6K and 10K managed switches contain an authentication bypass vulnerability that allows unauthenticated attackers to gain unauthorized access by exploiting a hardcoded string in the authentication mechanism. Attackers can bypass login controls to access administrative functions and sensitive switch configuration without valid credentials.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-798

Tecnología: No especificado

Publicado el: 2026-04-03



CVE-2017-20235

Descripción: ProSoft Technology ICX35-HWC version 1.3 and prior cellular gateways contain an authentication bypass vulnerability in the web user interface that allows unauthenticated attackers to gain access to administrative functions without valid credentials. Attackers can bypass the authentication mechanism in affected firmware versions to obtain full administrative access to device configuration and se...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-04-03



CVE-2017-20236

Descripción: ProSoft Technology ICX35-HWC versions 1.3 and prior cellular gateways contain an input validation vulnerability in the web user interface that allows remote attackers to inject and execute system commands by submitting malicious input through unvalidated fields. Attackers can exploit this vulnerability to gain root privileges and execute arbitrary commands on the device through the accessible w...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-04-03



CVE-2018-25236

Descripción: Hirschmann HiOS and HiSecOS products RSP, RSPE, RSPS, RSPL, MSP, EES, EESX, GRS, OS, RED, EAGLE contain an authentication bypass vulnerability in the HTTP(S) management module that allows unauthenticated remote attackers to gain administrative access by crafting specially formed HTTP requests. Attackers can exploit improper authentication handling to obtain the authentication status and privile...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-04-03



CVE-2021-4477

Descripción: Hirschmann HiLCOS OpenBAT and BAT450 products contain a firewall bypass vulnerability in IPv6 IPsec deployments that allows traffic from VPN connections to bypass configured firewall rules. Attackers can exploit this vulnerability by establishing IPv6 IPsec connections (IKEv1 or IKEv2) while simultaneously using an IPv6 Internet connection to circumvent firewall policy enforcement.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-284

Tecnología: No especificado

Publicado el: 2026-04-03



Resumen del Reporte

CVEs analizados: 55

Promedio CVSS: 9.04

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat ☹

